

How We've Gone Completely Phishing-resistant* (And So Can You!)

CypherCon 2026

whoami



Eric Woodruff



Chief Identity Architect
Microsoft Security MVP
IDPro Certified Identity Professional (CIDPRO)



@ericonidentity.com



@ericonidentity



/in/ericonidentity



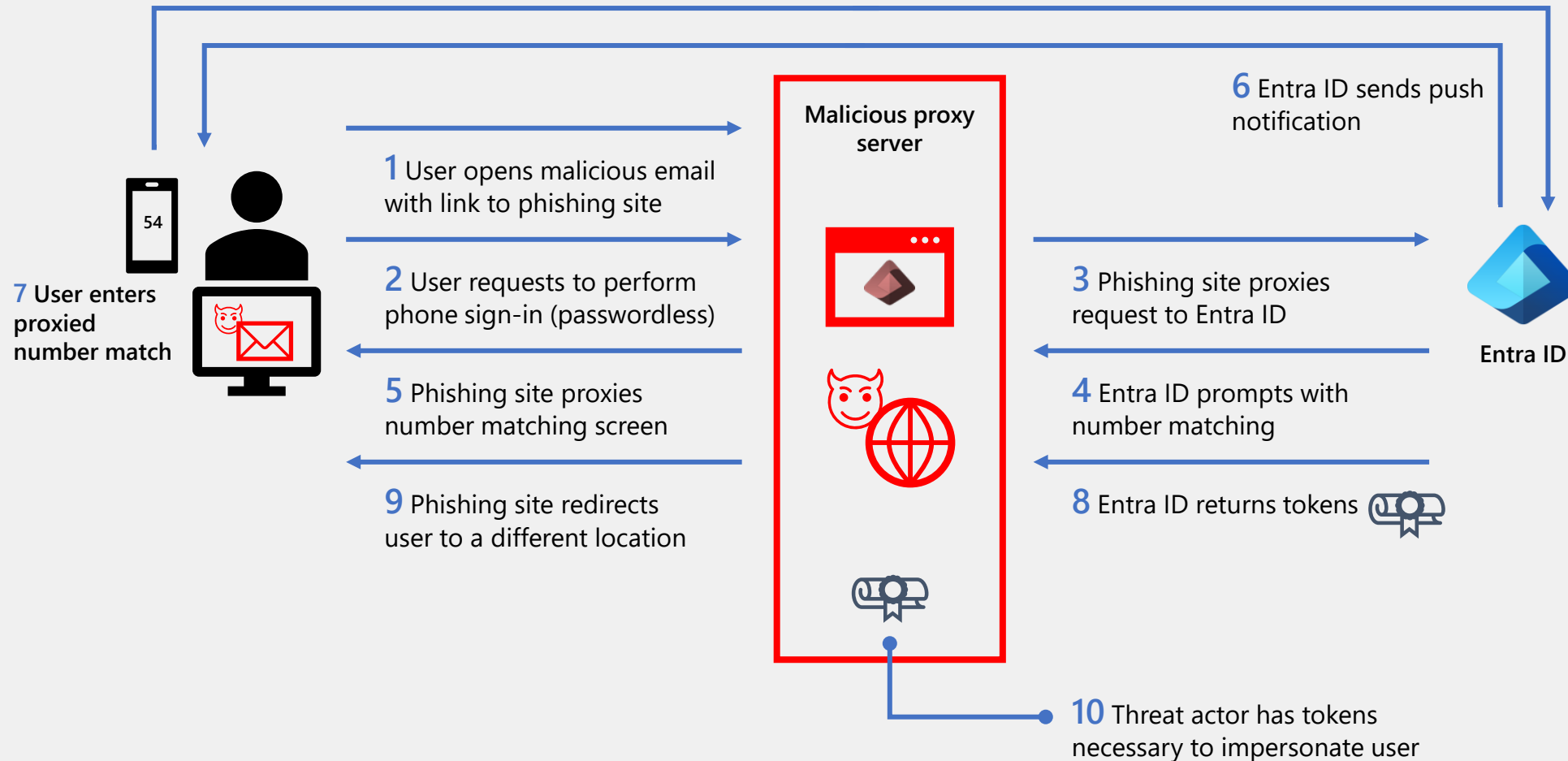
@ericonidentity@infosec.exchange

Agenda

- The problem
- Big braining
- Org side
- Tech side
- Still figuring out

The problem

Why passwordless is not good enough



Why users shouldn't have phishable options

[Blog](#) / Detection & response

MFA downgrade: How attackers are getting around phishing-resistant authentication



Luke Jennings
Vice President, R&D

Jul 21, 2025 | 8 min read

Share this post



Detection & response

Identity-based attacks

MFA downgrade (also known as auth downgrade) is an increasingly common technique used by attackers to bypass phishing-resistant authentication methods registered to an account — simply by selecting an alternative (phishable) method.



Enter your email address to view your
Salary/vacation plan.

For security reasons, Microsoft requires email verification before
continuing.

alex.wilber@horizonrealators.com

Verify email

If you need assistance, contact Microsoft Support.

So how do we get to phishing-resistant authentication?



Big braining

Consumer vs Workforce passkey deployments

Consumer

Implementation is app focused

Users generally accept adoption

You have the chance to build the experience for a specific user for a specific experience

Workforce

Implementation is IdP focused

Different risk scenario

Users can be your greatest friend and your worst enemy

Communication and organizational change management skills will be put to the test

What is phishing-resistant



Passkeys



Mac Platform SSO



Certificate based authentication



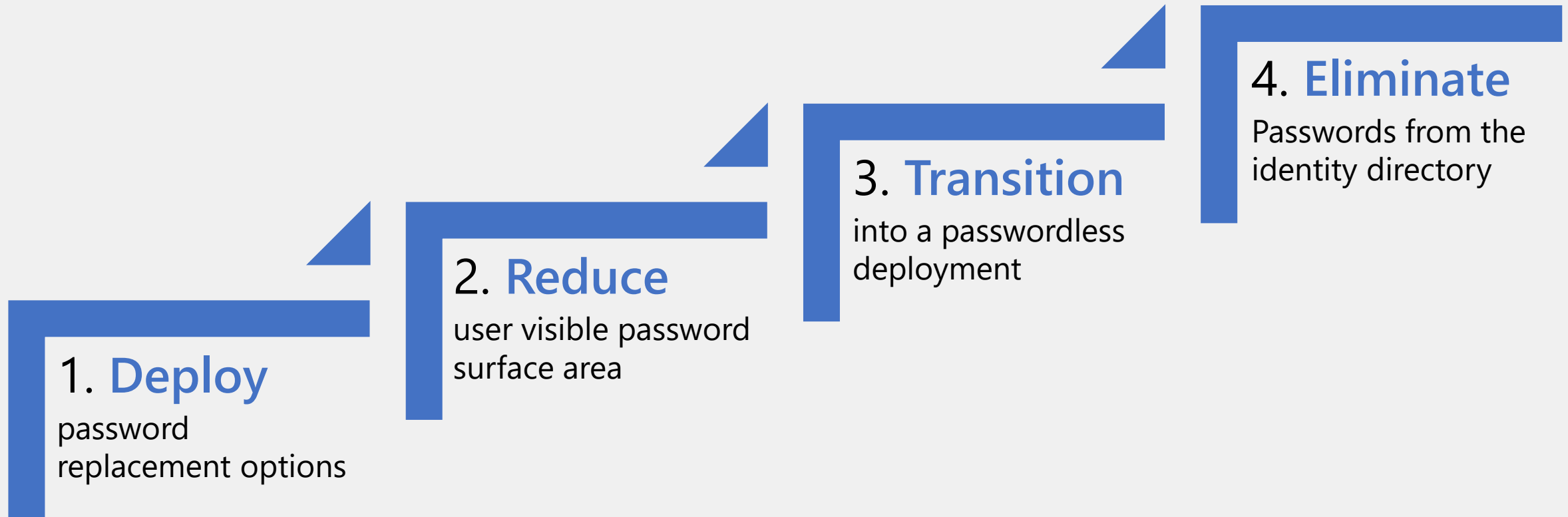
Windows Hello
for Business



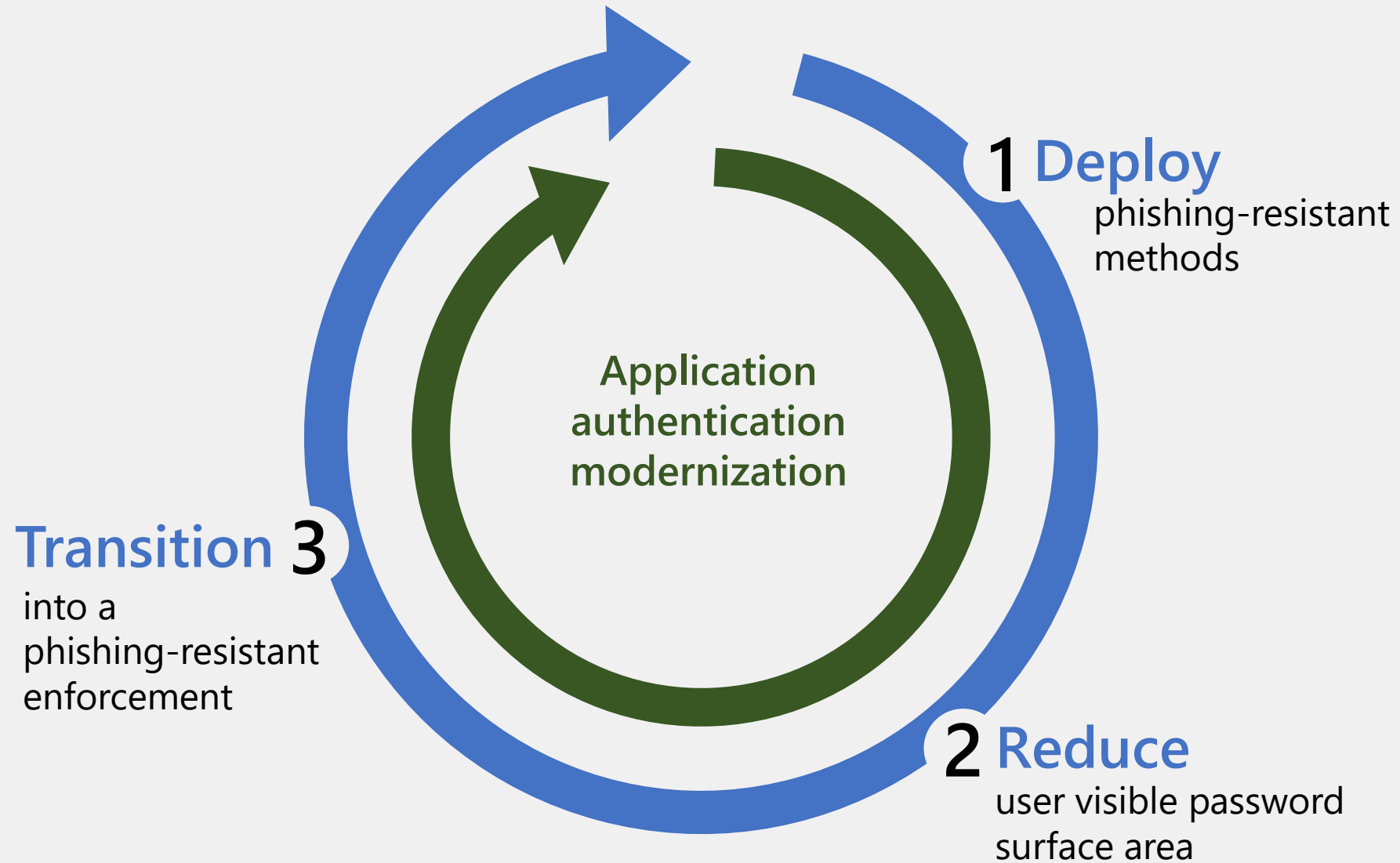
Device compliance

But we have *Active Directory*

The Microsoft passwordless journey



The iterative phishing-resistant journey





The org side



**Scan the QR code
to setup MFA**

Don't scan QR codes

**Scan the QR code
to authenticate**

Organizational Change Management



Awareness



Desire



Knowledge

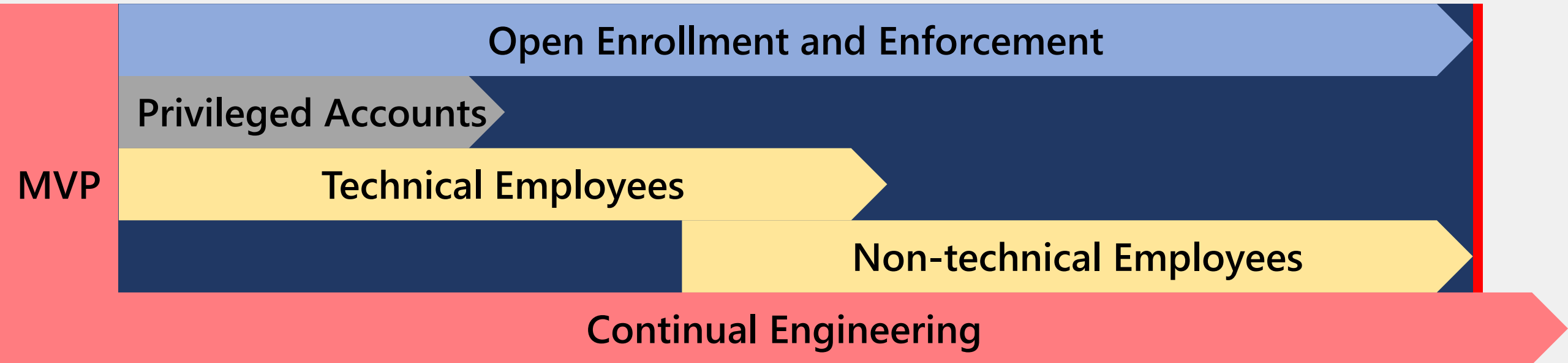


Ability



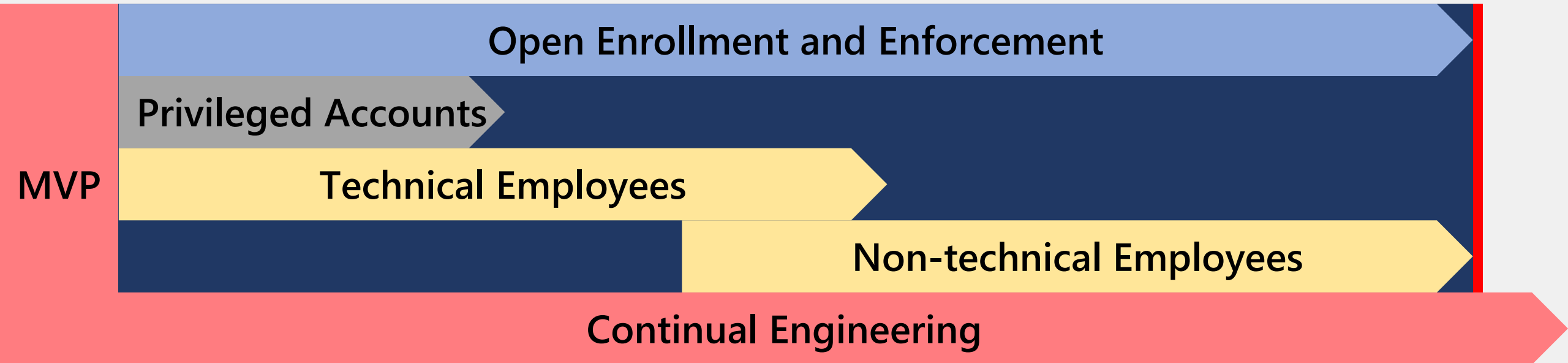
Reinforcement

Rings/waves/phases





Rings/waves/phases



Open enrollment program

Hi, Eric. When you submit this form, the owner will see your name and email address.

* Required

Phishing-resistant Authentication Overview

Phishing-resistant authentication helps protect users and Semperis from phishing attacks. As a cybersecurity company, Semperis and our employees are a high-value target for threat actors, and reducing the use of phishable forms of authentication is a priority in 2025.

The forms of phishing-resistant authentication at Semperis are:

- Windows Hello for Business
- FIDO2 hardware security keys
- Passkeys in Microsoft Authenticator app
- Mac Platform SSO

In order to be able to go phishing-resistant, we need employees to enroll in passkeys on their mobile devices.

1. I understand what phishing-resistant authentication is *



Yes



No

Next

Open enrollment program

* Required

Passkey Enrollment Review

To be onboarded into phishing-resistant authentication, a policy will be applied to your Semperis account that prevents you from using phishable forms of authentication in *most* instances.

Don't worry - it sounds more dramatic than it really is! The enrollment is easy, and since most employees are using Windows Hello for Business or Mac Platform SSO, you've already been phishing resistant when signing into laptops and workstations!

To ensure a smooth onboarding, it is **REQUIRED** that you have already enrolled in passkeys on the Microsoft Authenticator app.

If you elect enforcement before enrolling, you **WILL BE LOCKED OUT** on your mobile device.

For iPhone and iPad users: <https://portal.pnp.semperis.com/passkeys/apple/>

For Android users: <https://portal.pnp.semperis.com/passkeys/android/>

2. I've enrolled in passkeys for my Semperis user account *

☒ Yes

☐ No

Back

Next

Open enrollment program

* Required

Policy Behavior Change

Once you elect for self-enforcement of phishing-resistant authentication, a new policy will be applied to your Semperis user account, and you **will** be asked to re-authenticate on your mobile device, usually shortly after but within an hour or so.

Don't worry - it's not a big deal. If you want to understand what this experience will look like, view the details here:

iPhone and iPad: <https://portal.pnp.semperis.com/passkeys/apple/>

Android: <https://portal.pnp.semperis.com/passkeys/android/>

3. I understand the behavior change *

☒ Yes

☐ No

Back

Next

Open enrollment program

* Required

Policy Self Enforcement

Great! It looks like we are all set for you to elect to self enforce!
As an early adopter, you're a security champion in helping keep Semperis secure!

When you select **Yes** and submit, you should receive a confirmation email in a few minutes. After that, it can take from minutes up to an hour or so for the new policy to apply.

If you have technical issues, please open a support case with IT.

4. Enroll me in phishing-resistant authentication! *

☒ Yes

☐ No

Back

Submit

Passkeys at Semperis

End user passkey portal

Semperis employees one-stop shop for all things passkeys and phishing-resistant authentication.



Start Here

Project overview and why passkeys are important to you, and everyone at Semperis.



FAQ

Answers to all your questions about passkeys, phishing-resistant MFA, and this project at Semperis.



iPhone and iPad

Instructions on enrolling and using a passkey on an existing or new iPhone or iPad.



Android

Instructions on enrolling and using a passkey on an existing or new Android device.



Windows

Instructions on using a passkey on Windows.



Mac

Instructions on using a passkey on Macs.



FIDO2 Security Keys

Instructions on enrolling and using a FIDO2 security key.

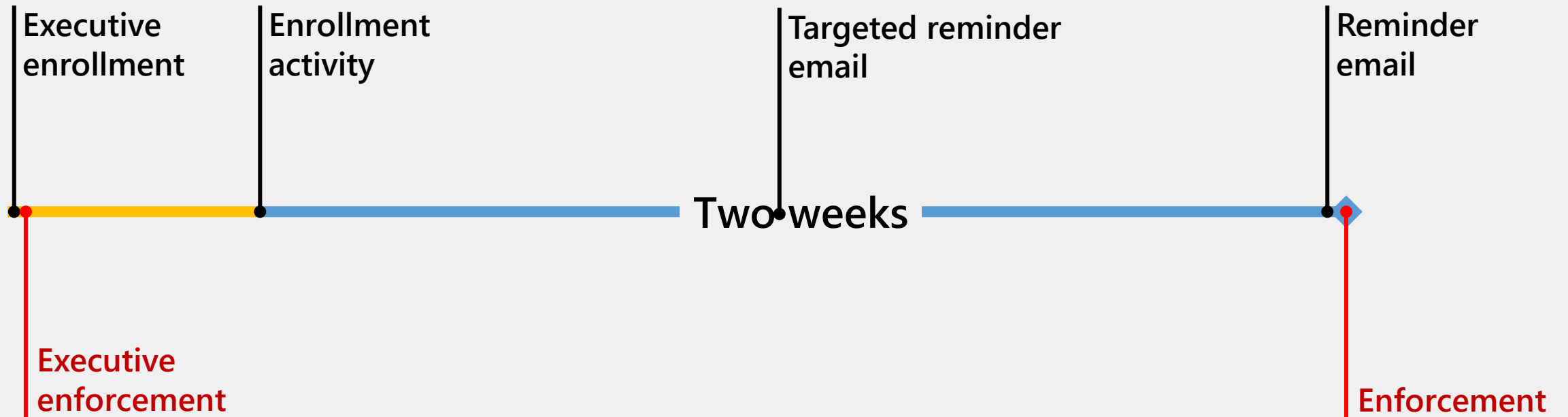


Synced passkeys

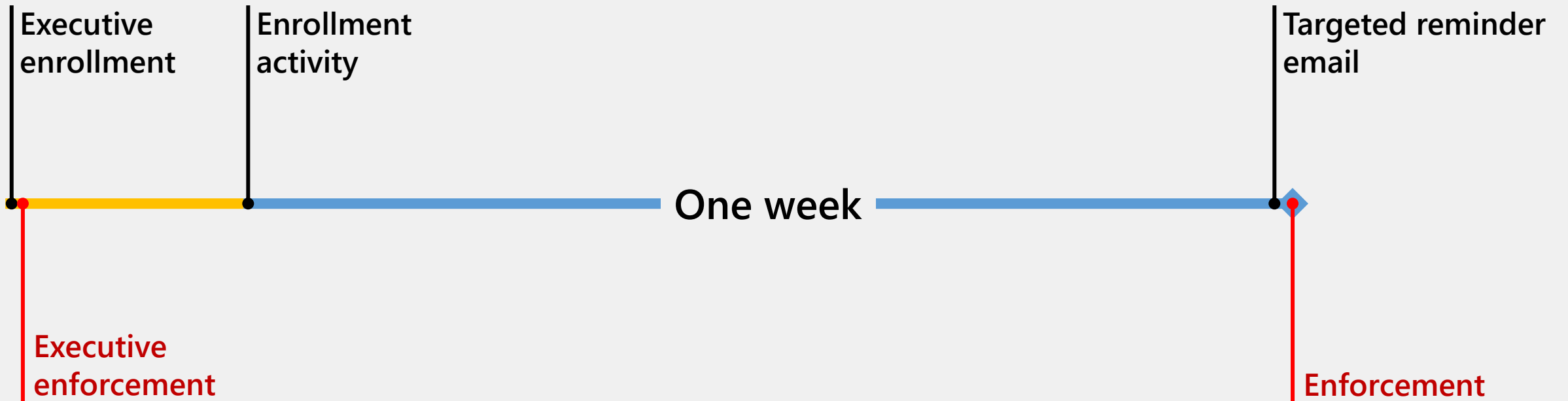
Instructions for enrollment and trying out synced passkeys.

End user portal

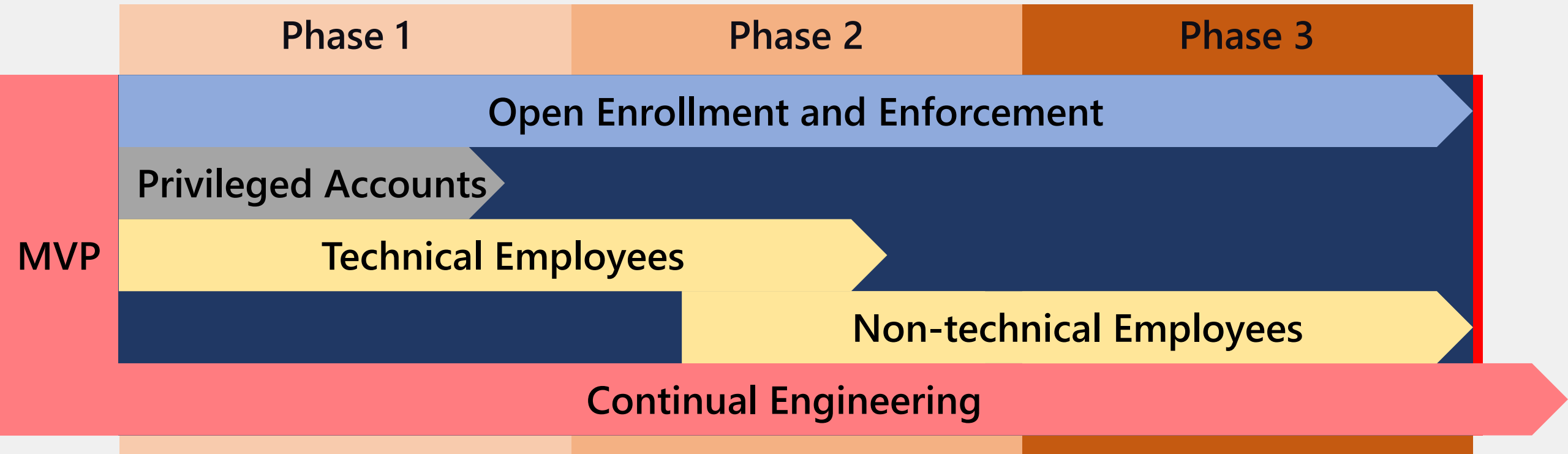
Phase 1 – Going slow



Phase 2 – Stepping on the gas



Rings/waves/phases

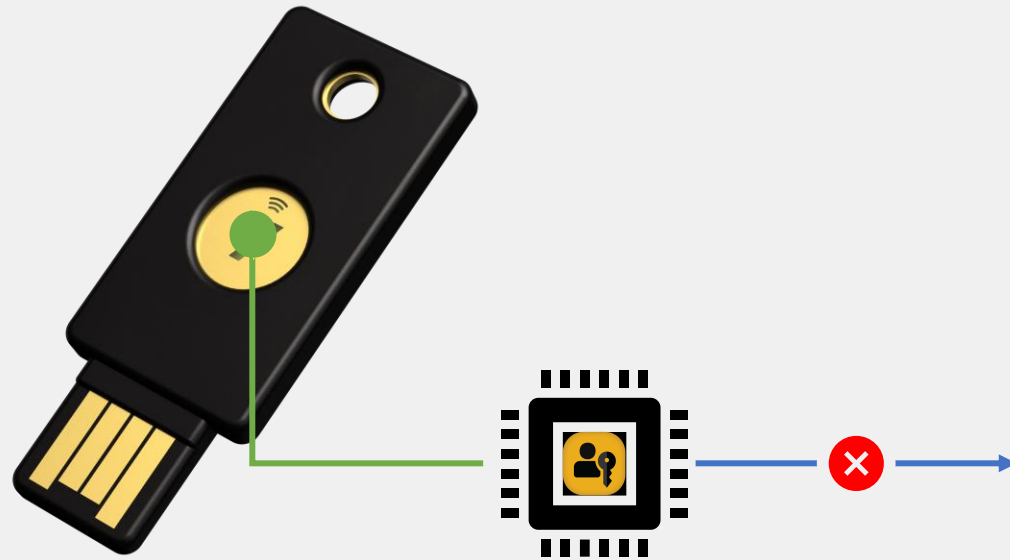


Phase 3 – Full throttle



The tech side

Device-bound passkey (FIDO2 key)



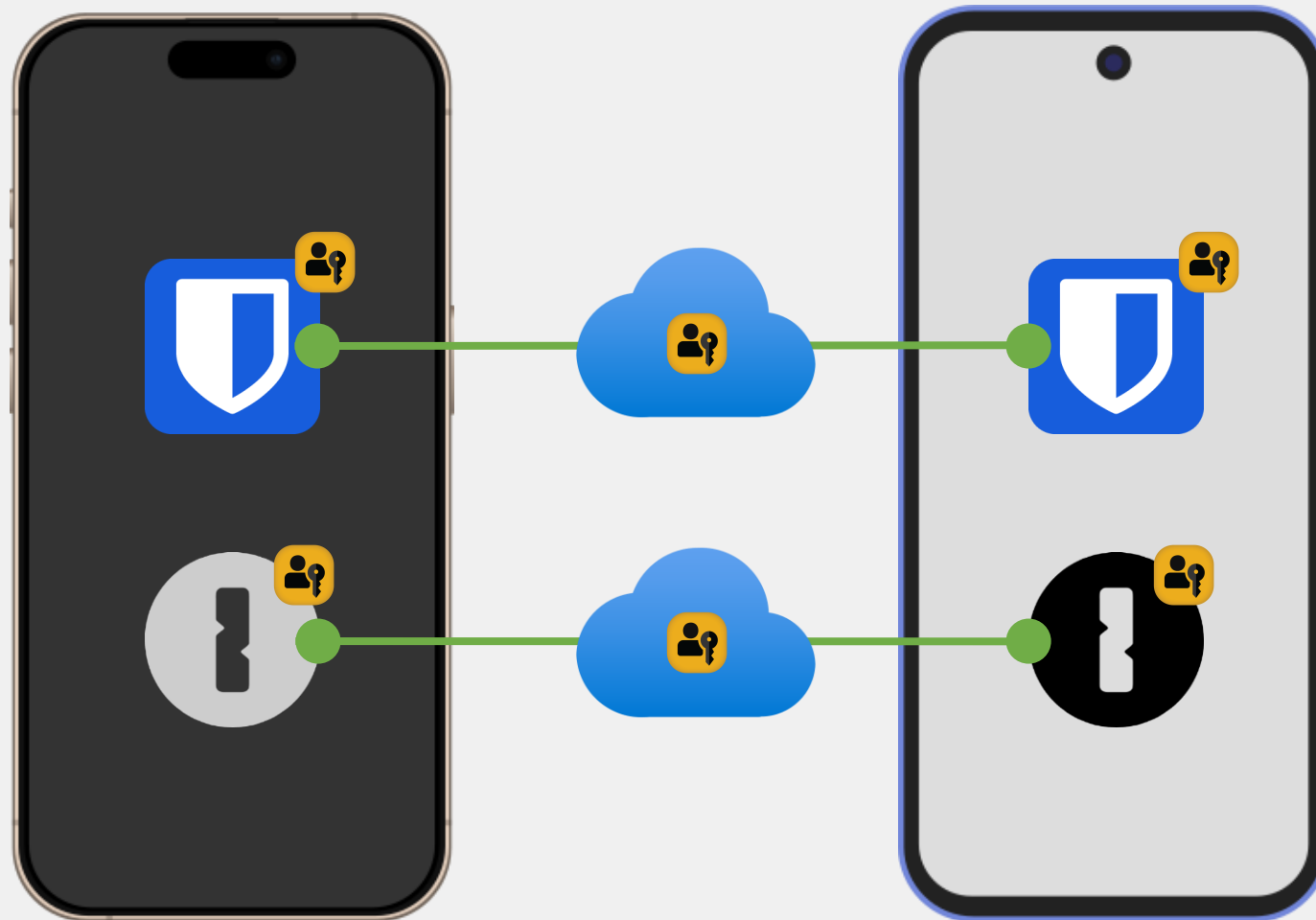
Device-bound passkey



Synced passkey



Synced passkey



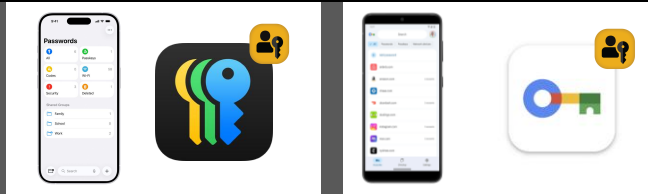
S



A



B



C



D

E

F

Synced passkeys



Your (Synced) Passkey is Weak

Copying private keys is a bad idea

Brought to you by  Allthenticate

Synced "passkeys" were created by Apple as means of vendor lock-in,
not as a security feature.

 Sign in with Passkey

Requires a device with iOS 17 or later.

Passkeys are only as secure as the mechanism that protects them.

Password manager credentials are phishable.

Disable passkeys in your password manager.

Use device-bound keys for real security.

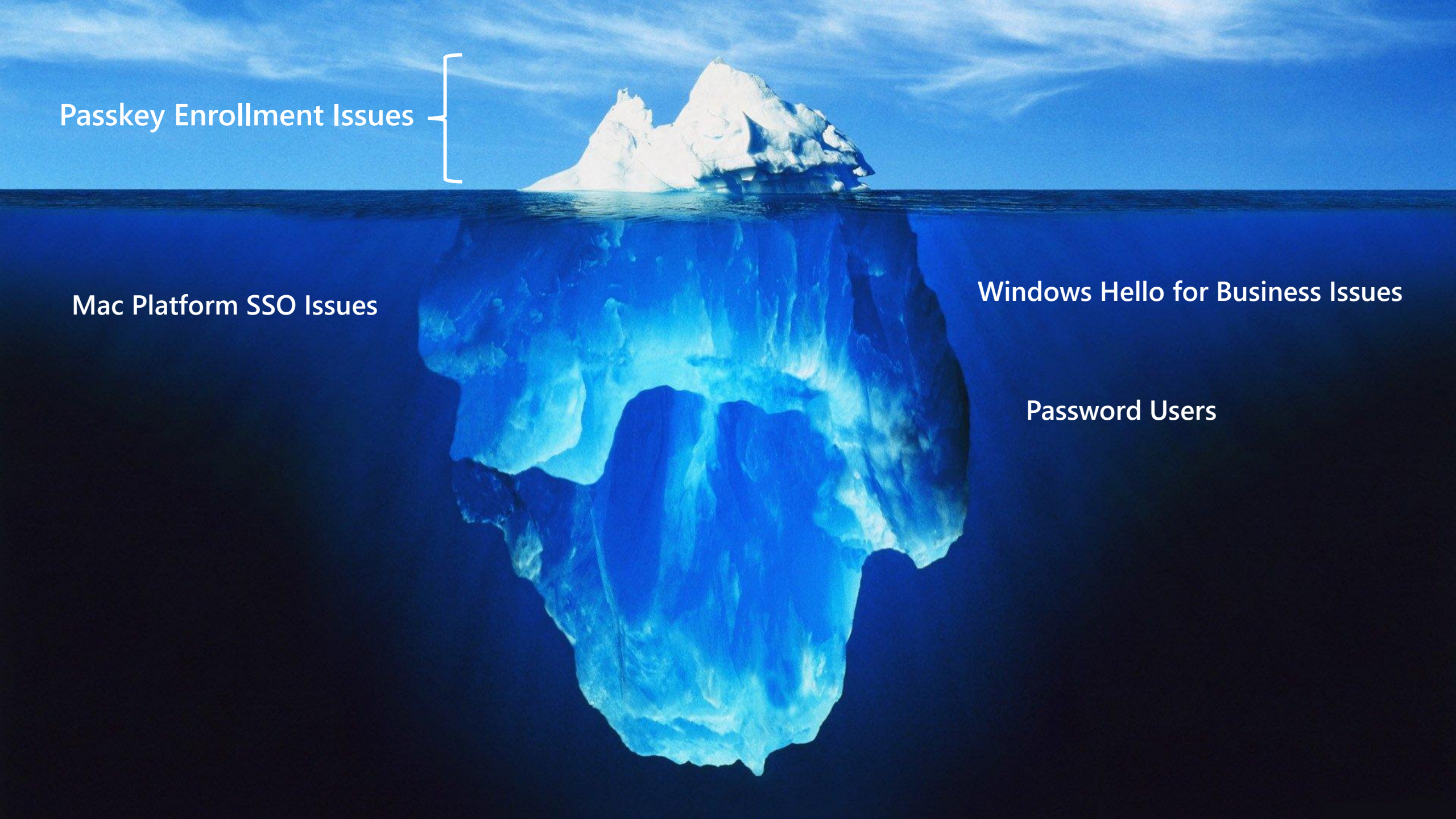
Not all passkeys are created equal.

synced passkeys are stored in cloud-based password managers, which **are phishable**.

device-bound passkeys never leave the hardware and are **effectively unphishable**.

Synced passkeys are putting you at more risk than passwords and
a second factor

Synced passkeys are about understanding the risk

An iceberg floating in a blue ocean under a blue sky. The visible tip of the iceberg is small, while the submerged part is much larger. Labels are placed around the iceberg to represent different categories of issues.

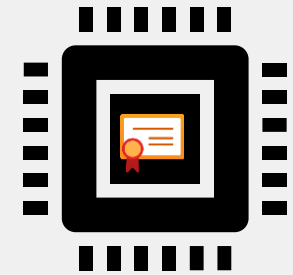
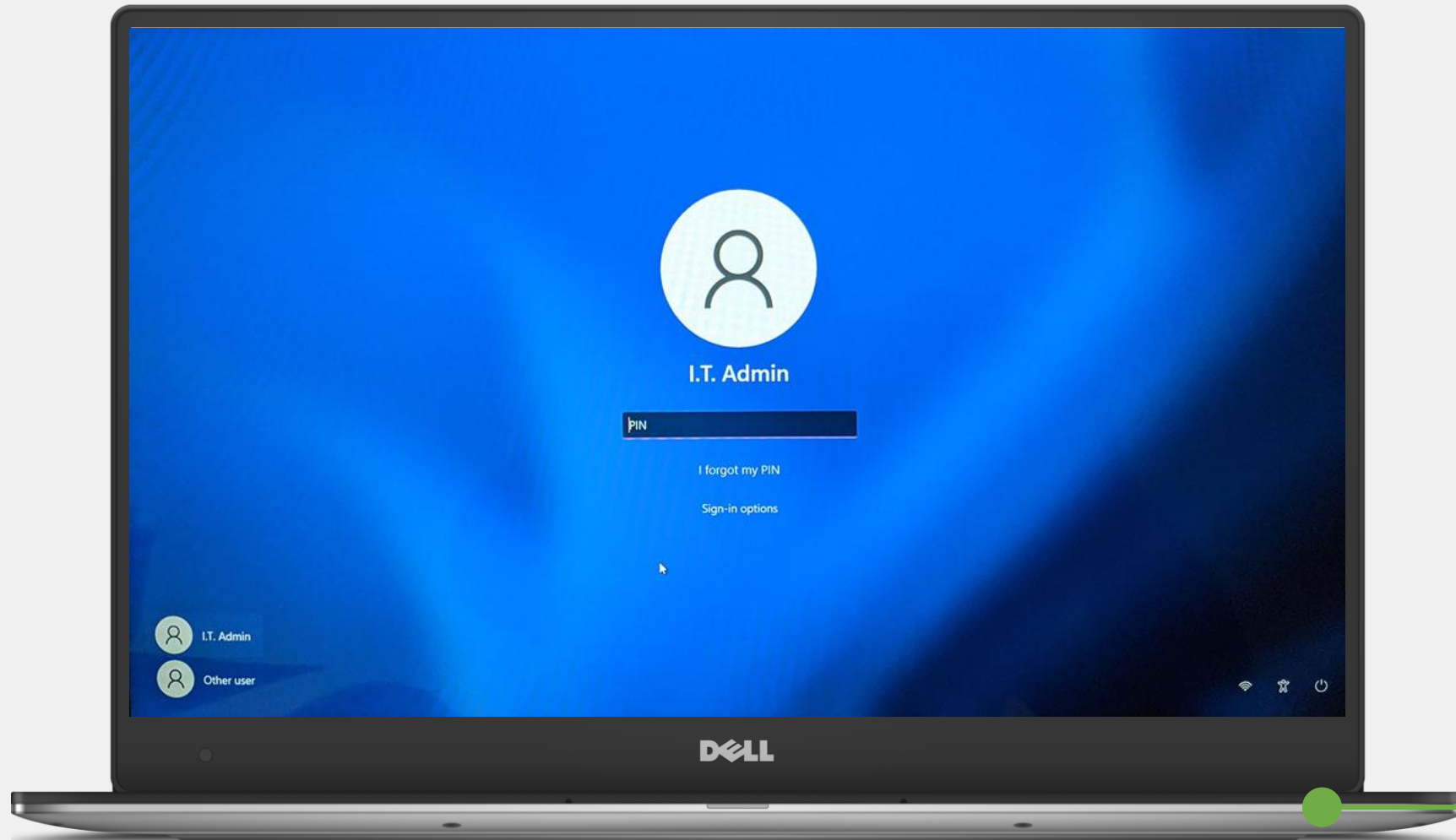
Passkey Enrollment Issues

Mac Platform SSO Issues

Windows Hello for Business Issues

Password Users

Windows Hello for Business



Windows Hello for Business

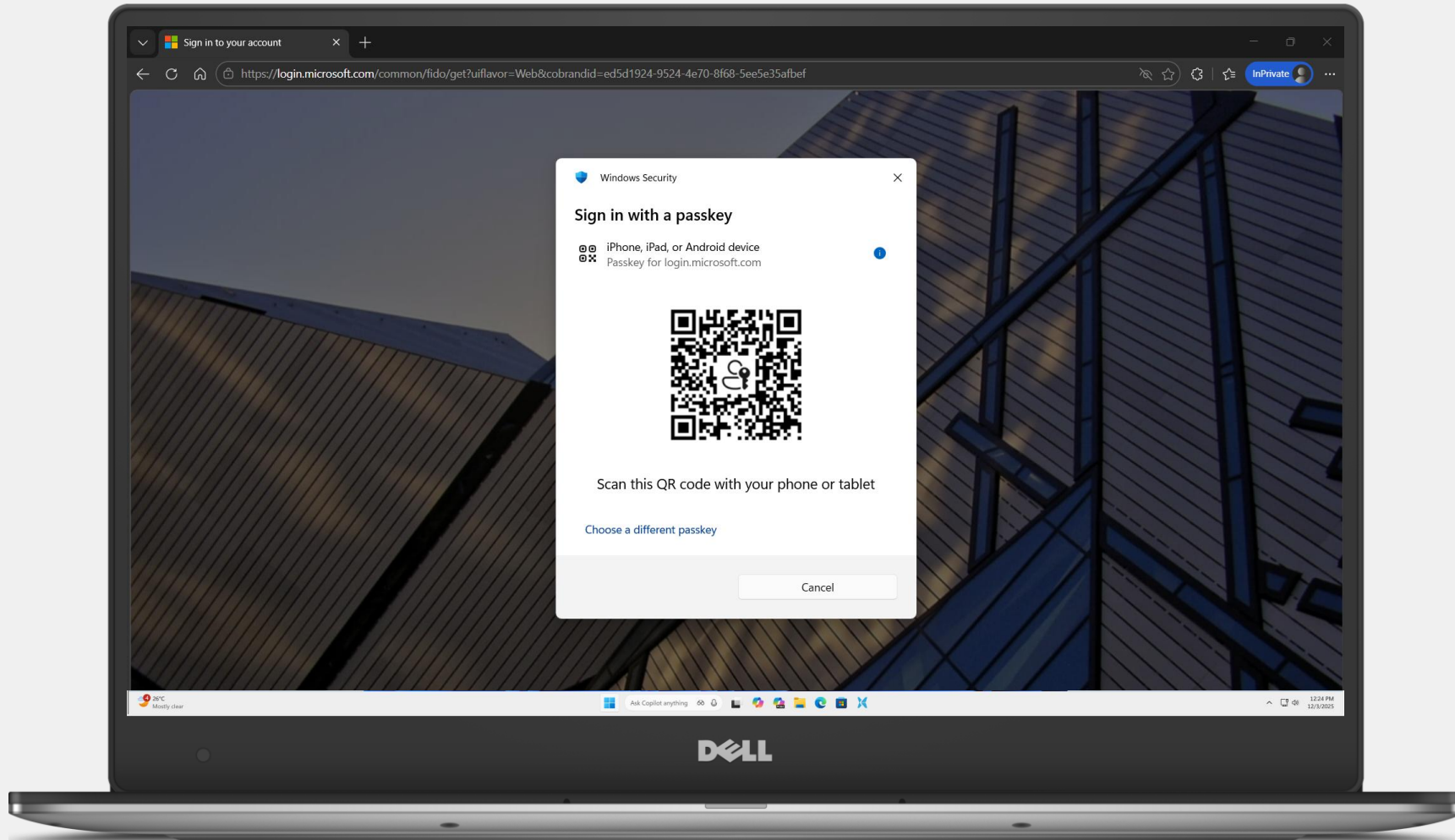


**Primary Refresh Token
(PRT)**



MFA Claim

Password sign-in



Primary Refresh Token
(PRT)



MFA Claim

Passkey Enrollment Issues

Mac Platform SSO Issues

Unsupported Applications

Linux Systems

Shadow IT

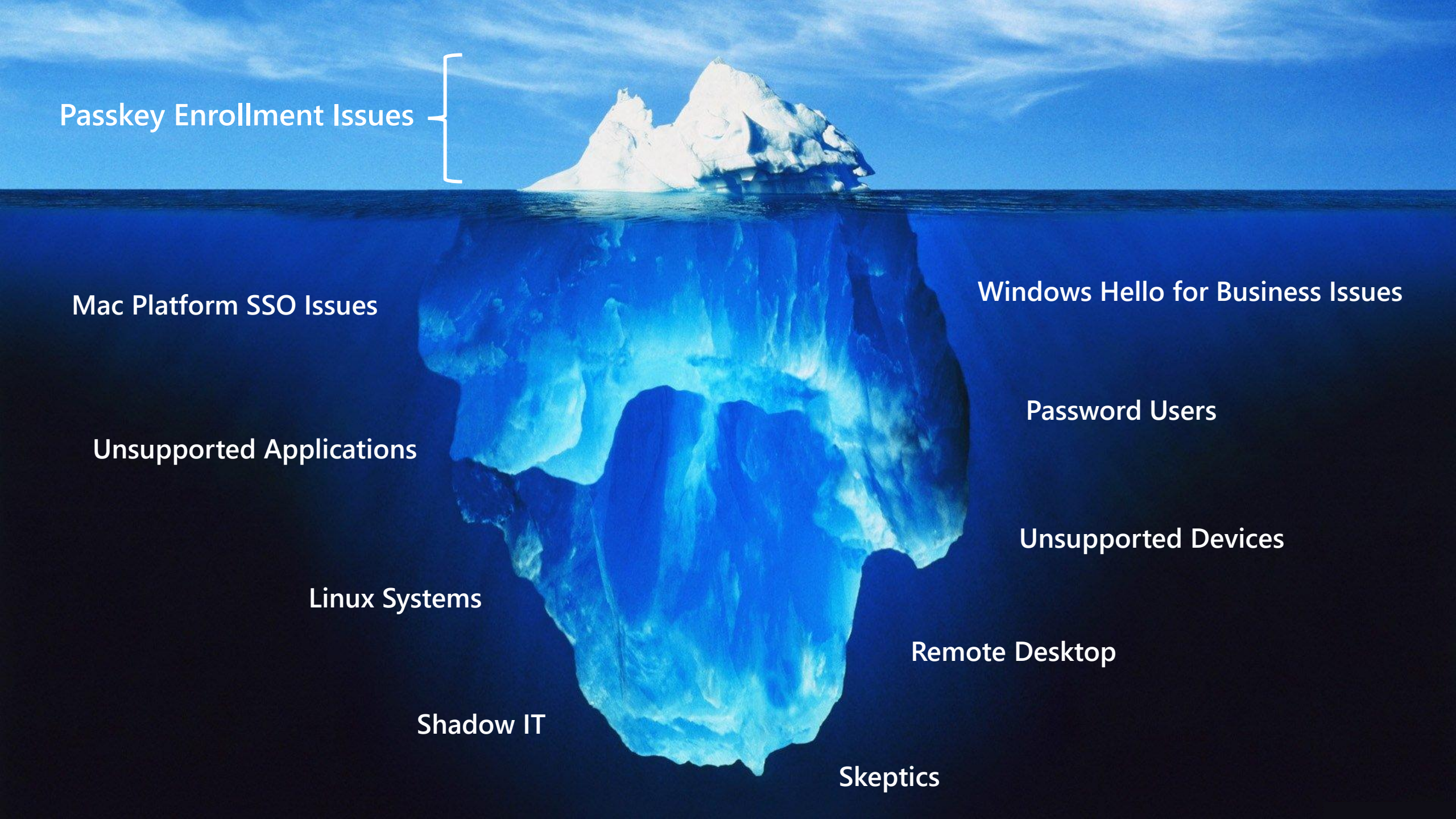
Windows Hello for Business Issues

Password Users

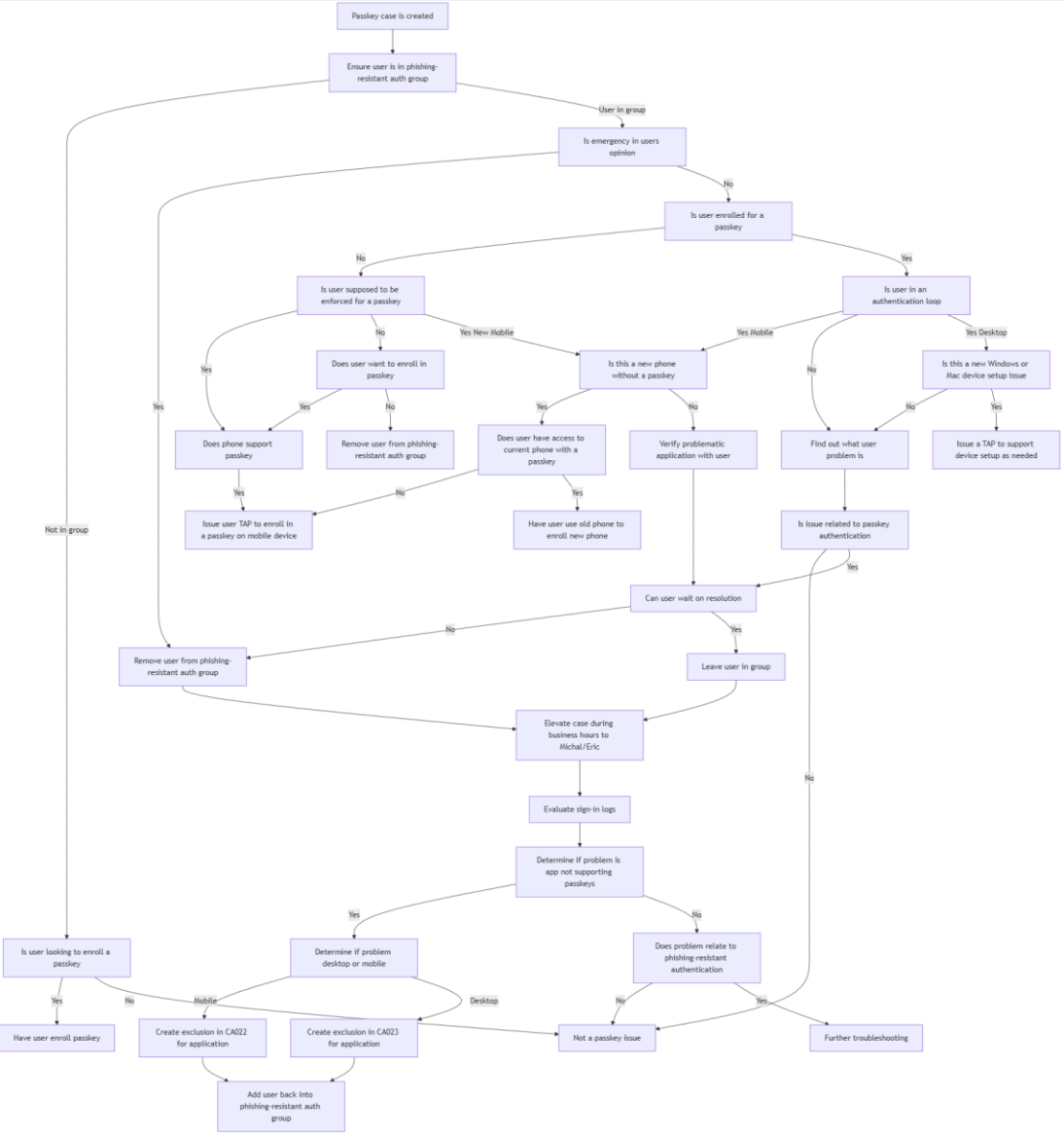
Unsupported Devices

Remote Desktop

Skeptics



Troubleshooting process



Verifying that the issue is application specific

The Entra ID sign-in logs for the user should be investigated for a "looping behavior".

Note that the behavior seen is not *specific* to passkeys, but the behavior is when a user has a conditional access policy enforced on them that the users authentication will never be able to satisfy. To put it another way, this error we look at is the behavior we see for passkeys, but this behavior itself is not a passkey specific error.

Search the users Entra ID sign-in logs

You will see a record for the application name, with a status of **Interrupted** and a sign-in error code of **50072**. Sometimes the error code might be **50140** or **500097**.

You will *then* see a successful sign-in to **Microsoft App Access Panel**.

Eric Woodruff	Success	0
Eric Woodruff	Interrupted	50072

On the *Interrupted* sign-in if you select it and then look at the *Conditional Access* tab, you will see a **Failure** for a phishing-resistant authentication policy.

Activity Details: Sign-ins

Basic info	Location	Device info	Authentication Details	Conditional Access	Report-only	...
Search						
Policy Name	Grant Controls	Session Controls	Result	...		
Require authentication strength			Success	...		
Require authentication strength			Success	...		
Require authentication strength			Failure	...		
Require app protection policy			Not Applied	...		

Conditional access policies

Coverage gap



Desktop

Client Applications

Browser

Mobile

Client Applications

Browser

Conditional access policies

Desktop

**Client applications – Everything
but iOS and Android**

**Browser – Everything but iOS and
Android**

Mobile

Client Applications

Browser

Conditional access Desktop – Device platforms

Device platforms

×

Apply policy to selected device platforms.
[Learn more](#)

Configure ⓘ

Yes No

Include

Exclude

☒ Any device

☐ Select device platforms

☐ Android

☐ iOS

☐ Windows Phone

☐ Windows

☐ macOS

☐ Linux

Device platforms

×

Apply policy to selected device platforms.
[Learn more](#)

Configure ⓘ

Yes No

Include

Exclude

☒ Android

☒ iOS

☐ Windows Phone

☐ Windows

☐ macOS

☐ Linux

Conditional access policy exceptions

Desktop

**Client applications – Everything
but iOS and Android**

**Browser – Everything but iOS and
Android**

Mobile

Client Applications

Browser

Conditional access policy exceptions

Desktop

Client applications – Everything
but iOS and Android

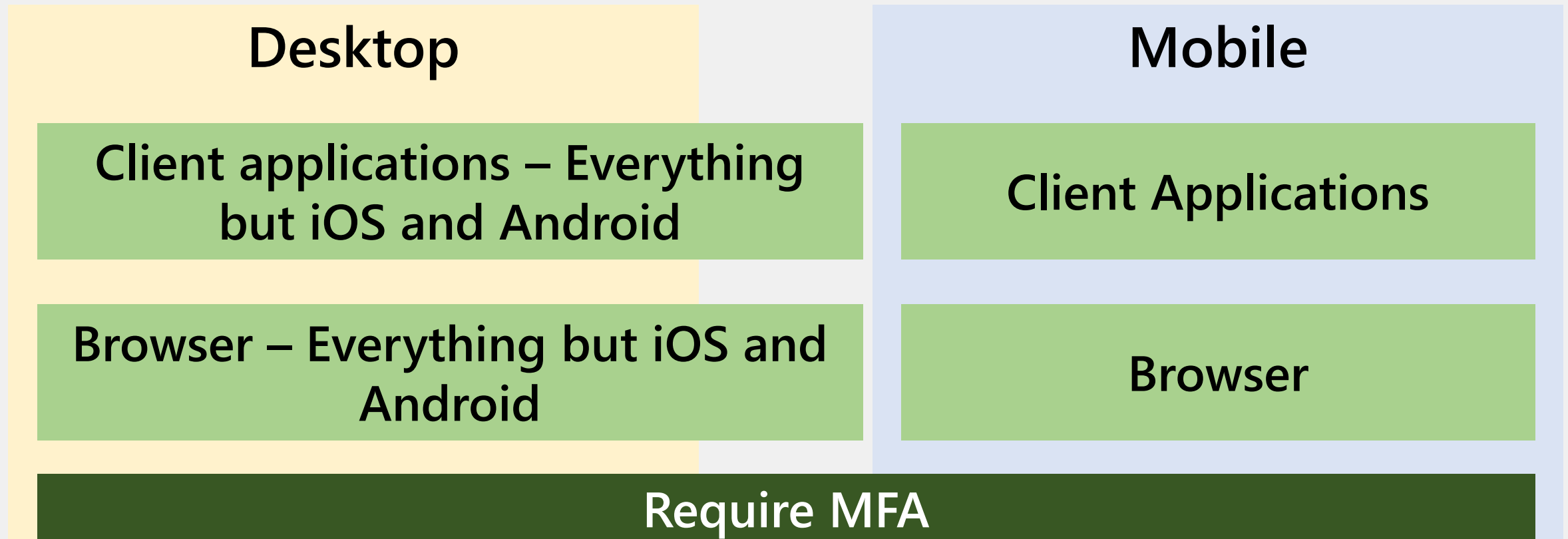
Browser – Everything but iOS and
Android

Mobile

Client Applications

Browser

Conditional access policy exceptions



FIDO2 Security keys

- Used in high security scenarios



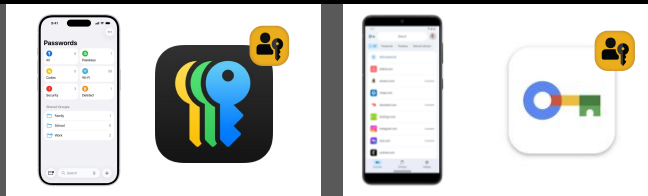
S



A



B



C



D

E

F

FIDO2 Security keys

- Used in high security scenarios
- Also offered as an option for user adoption



FIDO2 Security keys

- Used in high security scenarios
- Also offered as an option for user adoption
- The mobile NFC experience is underwhelming



Still figuring out

Things we are still noodling on

- Phone replacement

IPHONE USER

IPHONE 17

IPHONE 16



Things we are still noodling on

- Phone replacement
- Synced passkeys

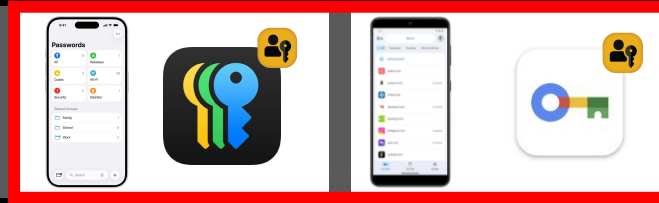
S



A



B



C



D

E

F

Things we are still noodling on

- Phone replacement
- Synced passkeys
- Employee self service
- Account recovery
- New employees

Questions?



@ericonidentity.com



@ericonidentity



/in/ericonidentity



@ericonidentity@infosec.exchange